Adaptive Protection Implementation — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Adaptive Protection in Microsoft Purview 5

The problem . . . 5

The solution . . . 5

How it works . . . 5

Why it matters . . . 5

Important boundaries . . . 6

Solution Overview — Adaptive Protection in Microsoft Purview 6

What this solution delivers . . . 6

Adaptive Protection is built on people-monitoring signals — read this first . . . 7

The Adaptive Protection model — how the pieces fit . . . 7

The standard deployment model . . . 8

What's in the box . . . 8

Requirements — Adaptive Protection in Microsoft Purview 9

R1. Licensing for IRM + DLP + (for the CA integration) Entra ID P2 . . . 9

R2. Least-privilege roles across IRM, DLP, and Conditional Access . . . 9

R3. An Insider Risk Management source signal (policy + privacy posture) . . . 10

R4. Adaptive Protection setup decision — Quick vs Custom (and the level→threshold mapping) . . . 10

R5. Sensitivity labels / classification for the DLP "label enforcement" rules . . . 10

R6. DLP coverage on the in-scope workloads . . . 11

R7. Conditional Access readiness (for the Elevated-risk access control) . . . 11

R8. HR, legal, privacy (and works-council) engagement and lawful basis . . . 11

R9. Pilot scope and change control (simulation / test / report-only) . . . 11

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 12

3. Security & Compliance PowerShell + Graph toolchain . . . 12

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 13

Implementation — Adaptive Protection in Microsoft Purview 14

Phase 0 — Assess (confirm you can build safely) . . . 14

Phase 1 — Design (agree it with HR/legal, then name everything) . . . 15

Phase 2 — Configure Adaptive Protection (the risk-level engine) . . . 15

Phase 3 — Build the DLP enforcement in SIMULATION/TEST first . . . 16

Phase 4 — Build the Conditional Access control in REPORT-ONLY first . . . 16

Phase 5 — Pilot and validate (run the gates) . . . 17
Phase 6 — Expand (enforce, then widen — only after the gate passes) . . . 17
Testing & Validation — Adaptive Protection in Microsoft Purview 18
Gate 1 — Licensing and roles are in place . . . 18
Gate 2 — The IRM source signal is scoring (and privacy is on) . . . 18
Gate 3 — Adaptive Protection is active with the three levels defined . . . 18
Gate 4 — The DLP policy is healthy, in SIMULATION, scoped to the pilot . . . 19
Gate 5 — The Conditional Access policy is in REPORT-ONLY with break-glass excluded . . . 19
Gate 6 — A sanctioned test account receives a risk level . . . 19
Gate 7 — DLP simulation shows the correct per-level action WOULD apply . . . 19
Gate 8 — CA report-only shows the Elevated control WOULD apply . . . 19
Gate 9 — Reporting reconciles with the portal . . . 20
Gate 10 — HR/legal confirm before enforcement . . . 20
Troubleshooting — Adaptive Protection in Microsoft Purview 20
No users are ever assigned a risk level . . . 20
The adaptive-protection risk-level condition is not visible when authoring a DLP rule . . . 21
The wrong DLP action fires for a user's level (e.g. block at Minor) . . . 21
DLP simulation shows no matches . . . 21
Conditional Access policy is not evaluating (report-only shows nothing) . . . 22
Risk of locking out administrators (Conditional Access) . . . 22
"It blocked legitimate work after we enforced" . . . 22
Permission / role errors running the scripts or authoring . . . 22
Reporting rollup doesn't match the portal . . . 22
Best Practices — Adaptive Protection in Microsoft Purview 23
1. Treat the risk level as an automation input, not a verdict . . . 23
2. Protect the source signal's privacy . . . 23
3. Always pilot in simulation / report-only first . . . 23
4. Make protection proportionate across the three levels . . . 24
5. Key enforcement on classification, not just risk . . . 24
6. Tune the mapping deliberately (Custom setup) . . . 24
7. Guard access continuity on the Conditional Access side . . . 24
8. Let risk levels decay — don't hard-code them . . . 24
9. Report on adaptive behavior, not on people . . . 24
10. Verify against your tenant — the surfaces evolve . . . 25
11. Keep the evidence trail intact . . . 25
Deliverables Summary — Adaptive Protection in Microsoft Purview 25

Documentation 25
PowerShell tools (5) 26
Named objects (verbatim — used across docs, scripts, and tests) 27
What this solution deliberately does NOT do 28
Appendix A — PowerShell Scripts 29

Executive Summary — Adaptive Protection in Microsoft Purview

The problem

Most data-protection controls treat everyone the same. The person who has never put a foot wrong is constrained exactly as much as the person quietly copying sensitive files on the way out the door. Static, one-size-fits-all controls force a bad trade-off: set them tight and you slow the whole organization down; set them loose and you leave the genuinely risky user under-controlled. Either way, protection is not aligned to where the risk actually is — and that is both an efficiency cost and a data-risk exposure.

The solution

This solution implements **Microsoft Purview Adaptive Protection**: protection that **dials up with the user's risk and relaxes as it subsides**. It takes the **insider risk level** Purview computes for a user — **Elevated, Moderate, or Minor** — and feeds it as a **live condition** into your protective controls:

- **Data Loss Prevention** — the **same** attempted action on sensitive, labeled content is **audited** for a low-risk (Minor) user, **warned/overridable** for a Moderate user, and **blocked** for an Elevated user.
- **Conditional Access** — access for an **Elevated-risk** user can be blocked, stepped up, or limited, while everyone else signs in normally.

The risk level is **dynamic and time-bound**: it rises when behavior warrants and **decreases automatically** as behavior normalizes — so controls are responsive, not permanent punishments.

How it works

We follow a repeatable model — **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** — that confirms the **insider-risk source signal and its privacy guardrails first**, enables Adaptive Protection (Microsoft's recommended **Quick setup**, or a mapped **Custom setup**), then builds the DLP enforcement in **simulation/test** and the Conditional Access control in **report-only** before anything blocks. Every high-impact control is piloted, proportionate to risk, and reversible.

The solution ships as **self-guided documentation plus five PowerShell tools** (Security & Compliance PowerShell / Graph) that assess readiness and the source signal, scaffold and validate the adaptive DLP policy, check the end-to-end wiring, and produce a leadership rollup — all **read-only or `-WhatIf`/simulation by default**, with **no credentials in code**.

Why it matters

- **Protection where the risk is** — strong for the genuinely risky user, frictionless for everyone else, instead of blunt controls that punish the whole organization.
- **Automatic and self-adjusting** — risk levels rise and fall on their own; protection follows, without manual re-classification.
- **Proportionate and defensible** — audit → warn → block scaled to risk, keyed to your most sensitive

labeled content, with an evidence trail.

• **A fraction of consulting cost** — the same disciplined method a specialist would use, delivered as a repeatable, tested runbook.

Important boundaries

Adaptive Protection is **driven by Insider Risk Management**, which monitors **people's activity**: in many jurisdictions the underlying monitoring requires notice, consultation, or a specific **lawful basis** before it runs — that applicability is a **legal determination** for your organization, and this solution provides the technical method and guardrails, not the legal decision. A user's risk level tightens **controls**, not judgement — whether risky activity reflects misconduct, and any consequence, remains an **HR/legal determination**. Adaptive Protection is **licensing-dependent** (Microsoft 365 E5 / E5 Compliance for IRM + DLP; **Entra ID P2** for the Conditional Access integration; some capabilities may be in preview) and the Purview/Entra portals are **evolving** — capability availability and paths should be **verified against your licensing and tenant**.

Solution Overview — Adaptive Protection in Microsoft Purview

What this solution delivers

Most data-protection programs apply **the same controls to everyone**. The finance analyst who has never triggered a single alert is blocked exactly as hard — or as softly — as the person who copied a customer database to a USB stick on the day they resigned. Static controls are blunt: turn them up and you throttle the whole organization; turn them down and you leave the genuinely risky user under-controlled. **Microsoft Purview Adaptive Protection** closes that gap. It takes the **insider risk level** Purview already computes for a user (**Elevated / Moderate / Minor**) and feeds it, as a **live condition**, into your protective controls — so protection **dials up automatically for the users who are actually behaving riskily** and stays out of the way for everyone else.

This solution walks a competent-but-novice administrator through a **complete, repeatable Adaptive Protection deployment**:

1. **Stand up (or confirm) the insider-risk signal that drives everything** — Adaptive Protection is powered by **Insider Risk Management (IRM)**: an insider-risk policy scores activity, and Adaptive Protection maps that scoring onto the three dynamic risk levels. No IRM signal, no adaptive behavior.

1. **Configure Adaptive Protection** — using **Quick setup** (Microsoft's recommended default mapping) or **Custom setup** (map each risk level to specific insider-risk policies and thresholds), so users start receiving a **dynamic, time-bound risk level**.

1. **Make the risk level enforce protection** across three surfaces, **piloted in simulation/test / report-only first**:

• **Data Loss Prevention (DLP)** — a DLP policy whose rules use *"a user's risk level for adaptive

protection is …"* as a condition, so the **same** attempted action is **audited** for a Minor user, **warned/overridable** for a Moderate user, and **blocked** for an Elevated user — and, by scoping the rules to **sensitivity-labeled** content, protection on your most sensitive (labeled) data scales with the person handling it.

• **Microsoft Entra Conditional Access** — an insider-risk-conditioned access policy that can

block, step-up, or limit the session for Elevated-risk users, deployed in **report-only** first.

1. **Validate, then expand** — prove the end-to-end path (activity → score → risk level → DLP/CA

action) with a **sanctioned test**, then widen scope deliberately.

Together these turn a **blunt, one-size-fits-all posture** into a **risk-adaptive** one: strong where it needs to be, frictionless where it does not — configured, piloted, validated, and defensible.

Adaptive Protection is built on people-monitoring signals — read this first

Adaptive Protection is **driven by Insider Risk Management**, which evaluates **people's activity**. That inherits IRM's employee-privacy, works-council, labour-law, and data-protection obligations — this is **not** a plain DLP or labeling project. Three principles run through every step:

• **Privacy by design in the source signal.** The IRM policy that feeds Adaptive Protection runs with

IRM's **anonymization (pseudonymization)** guardrails and **role separation** intact. Adaptive Protection consumes a **risk level**, not a dossier — but the signal underneath it is people data, so scope to the **minimum** population and keep the IRM privacy posture on.

• **The risk level automates protection, not judgement.** A user reaching *Elevated* means their

controls tighten — it is **not** a finding of misconduct. Whether risky activity reflects wrongdoing, and any consequence, remains an **HR/legal determination** (see IRM), never a technical default and never the administrator's call.

• **High-impact, so pilot first.** DLP block actions and Conditional Access grant controls can stop

legitimate work if mis-scoped. **Every** protective control here is deployed in **simulation/test (DLP)** or **report-only (Conditional Access)** first, validated, and only then enforced.

> ***Deploy this with HR, legal, and privacy*** *(and, where applicable, works-council / employee representatives) — the same stakeholders IRM requires. The* ***lawful basis / applicability*** *of monitoring is a* ***legal determination*** *for your organization; this solution provides the technical method and the guardrails, not the legal decision (see* `global-requirements-purview.md` *§5).*

The Adaptive Protection model — how the pieces fit

• **Risk levels.** Adaptive Protection classifies each in-scope user into one of three **dynamic,

time-bound **levels:** Elevated**,** Moderate**, or** Minor**. The level rises when the user's insider-risk activity crosses the mapped threshold and** decreases automatically** over time as behavior normalizes — so protection is responsive, not permanent.

• **The source signal (IRM).** The levels are derived from **Insider Risk Management** scoring. You

either let Adaptive Protection use the **recommended default** (Quick setup, backed by a Microsoft default insider-risk policy) or map levels to **specific insider-risk policies and thresholds** (Custom setup) — e.g.

Elevated = a high-severity insider-risk alert; Moderate = medium; Minor = low.

• **The protective controls (consumers of the level).** Once Adaptive Protection is on, the risk level becomes a **selectable condition** in:

• **Purview DLP** — the condition *"the user's risk level for adaptive protection is Elevated/Moderate/Minor"* on DLP rules, so actions (audit → warn/override → block) scale with the level. Combine with a **sensitivity-label** condition to make the strongest protection apply to labeled sensitive content.

• **Entra Conditional Access** — the **Insider risk** condition, so access controls (block / require MFA / limited session) apply to Elevated-risk users.

• **The loop.** Activity → IRM scores it → Adaptive Protection assigns a level → DLP/CA read the level and adapt → as behavior normalizes the level decays and controls relax. It is **self-adjusting** by design.

> ***Label enforcement, precisely.*** *"Label enforcement" here means* ***DLP rules that combine the adaptive-protection risk-level condition with a sensitivity-label condition*** *— protection on labeled content scales with the handler's risk. The* ***primary, documented*** *Adaptive Protection integrations are* ***DLP*** *and* ***Conditional Access****; treat any additional integration as* ***"verify availability in your licensing/tenant."***

The standard deployment model

Every step follows the same repeatable model, with an explicit **pass/fail gate** between phases:

Assess → Design → Configure → Pilot (simulation/test / report-only) → Validate → Expand (enforce).

• **Assess** — confirm licensing (E5 / E5 Compliance for IRM + DLP; **Entra ID P2** for the CA integration), roles, the IRM signal, the in-scope labeled data, and HR/legal/privacy sign-off.

• **Design** — decide Quick vs Custom setup and the level→threshold mapping, the DLP rules per level, the CA control for Elevated, the pilot scope, and name every object — **with HR/legal**.

• **Configure** — confirm/stand up the IRM source policy, enable Adaptive Protection, then build the DLP policy (in **simulation/test**) and the CA policy (in **report-only**).

• **Pilot** — run in simulation/test/report-only; verify levels are assigned and rules *would* act, without blocking anyone yet.

• **Validate** — run the pass/fail gates in `05-testing.md`.

• **Expand** — turn DLP to enforce and CA to on, then widen scope **only** after the gate passes.

What's in the box

• This overview, a **Requirements** guide, an ordered **Implementation** guide, **Testing** (pass/fail gates), **Troubleshooting**, **Best Practices**, and a **Deliverables Summary** + **Executive Summary**.

• **Five PowerShell tools** (Security & Compliance PowerShell / Graph): an Adaptive Protection

readiness/discovery assessment, a **DLP-policy configuration helper** (`-WhatIf`/simulation first), a **validation** checker, an **enforcement reporting** rollup, and a **scope helper** — read-only or `-WhatIf` by default; **no credentials in code**.

> ***Sources:*** *Microsoft Learn — *Adaptive Protection in Microsoft Purview* (learn about / quick & custom setup, risk levels), *Insider Risk Management*, *Data Loss Prevention* (conditions/actions, simulation mode), and *Microsoft Entra Conditional Access* (insider risk condition, report-only). Adaptive Protection is **licensing-dependent** (Microsoft 365 E5 / E5 Compliance for IRM + DLP; **Entra ID P2** for the Conditional Access integration; some capabilities may be in preview) and the Purview/Entra portals are **evolving — verify capability availability and portal paths against your licensing/tenant** rather than assuming.*

Requirements — Adaptive Protection in Microsoft Purview

Confirm every prerequisite below **before** you configure anything. Category-level prerequisites (tenant, licensing model, least-privilege roles, S&C PowerShell / Graph toolchain, in-scope data sources, compliance/privacy/legal stakeholders, pilot scope + change control) are in `global-requirements-purview.md` — reference them; they are **not** repeated here. The items below are the ones **specific to Adaptive Protection** and its three moving parts: the **Insider Risk Management** source signal, **DLP** enforcement, and the **Conditional Access** integration.

Each requirement is written as **Description · Why · Verify · Implement if missing.**

> *Adaptive Protection is **driven by Insider Risk Management**, so it inherits IRM's HR/privacy sensitivity. Several requirements below are **organizational, not technical** (HR/legal engagement, lawful basis). Treat those as hard gates: they must be satisfied before you enable enforcement, and their determination is **not yours to make** — see `global-requirements-purview.md` §5.*

R1. Licensing for IRM + DLP + (for the CA integration) Entra ID P2

Description: Microsoft 365 **E5** or the **E5 Compliance** add-on (for **Insider Risk Management** and **Data Loss Prevention**), assigned to the users who will be **in scope**; and **Microsoft Entra ID P2** (included in E5) for the **Conditional Access** insider-risk integration. **Why:** Adaptive Protection is built on IRM (premium/plan-gated) and enforced through DLP; the CA integration additionally needs Entra ID P2. Without the right licences the risk levels, the DLP condition, or the CA condition will not be available, and in-scope users must be licensed. **Verify:** Microsoft 365 admin center → **Billing** → **Licenses** — confirm E5 / E5 Compliance and Entra ID P2. In the Purview portal, **Insider Risk Management** → **Adaptive Protection** is present; the adaptive-protection **risk-level condition** appears when authoring a DLP rule. Cross-check advanced features against the *Microsoft Purview service description* — **verify against your licensing/tenant. Implement if missing:** Acquire and assign the required SKUs/add-ons before enabling Adaptive Protection or authoring enforcement.

R2. Least-privilege roles across IRM, DLP, and Conditional Access

Description: The least-privilege roles for each surface, mapped to **named** people:

- **Insider Risk Management Admins** (and the IRM Analysts/Investigators/Auditors separation) to own the source policy and Adaptive Protection setup — see the IRM role-separation discipline.

• **Compliance Administrator / Compliance Data Administrator** (or **DLP Compliance Management**) to

author the DLP policy.

• **Conditional Access Administrator** (or Security Administrator) in Entra to author the CA policy;

Global Administrator only where genuinely required. **Why:** Each surface uses its own role model; configuring across three surfaces requires the matching least-privilege role on each, without over-granting. **Verify:** Purview → **Roles & scopes / Permissions** (IRM + DLP roles); Entra → **Roles & admins** (CA role). `PURVAP-Discovery.ps1` reports the IRM/DLP role signals it can read. **Implement if missing:** Assign the least-privilege role on each surface under change control; keep IRM role separation intact (do not fold IRM admin into DLP/CA admin for convenience).

R3. An Insider Risk Management source signal (policy + privacy posture)

Description: A working **IRM policy** whose scoring can drive risk levels (for **Quick setup**, Microsoft's built-in default insider-risk policy; for **Custom setup**, one or more named insider-risk policies), with IRM's **anonymization** on and **role separation** intact. **Why:** Adaptive Protection does not generate its own signal — it **maps IRM scoring** onto Elevated/ Moderate/Minor. No scoring source, no risk levels, no adaptive behavior. **Verify:** Purview → **Insider Risk Management** → **Policies** shows a policy that is **On** and scoring; **Settings** → **Privacy** shows anonymization on. `PURVAP-Discovery.ps1` reports whether an IRM policy is present/readable and prompts to confirm the privacy posture in-portal. **Implement if missing:** Stand up (or reuse) an insider-risk policy — e.g. a **Data leaks** policy — before enabling Adaptive Protection. Keep the IRM privacy guardrails on.

R4. Adaptive Protection setup decision — Quick vs Custom (and the level→threshold mapping)

Description: A decision on **how risk levels are assigned**: **Quick setup** (Microsoft's recommended default mapping to a built-in insider-risk policy) or **Custom setup** (map each level — **Elevated / Moderate / Minor** — to specific insider-risk policies and thresholds, e.g. by alert severity or number of exfiltration activities), agreed with HR/legal. **Why:** The mapping determines **who** reaches which level and therefore **who** gets tighter controls; it directly affects both protection and fairness, so it is a decision, not a default. **Verify:** Purview → **Insider Risk Management** → **Adaptive Protection** shows the chosen setup and the per-level definitions. **Verify the exact options against your tenant** (the setup UI evolves). **Implement if missing:** Choose Quick setup to start (lowest effort, recommended default) and move to Custom only when you need explicit control over the mapping. Record the mapping with HR/legal.

R5. Sensitivity labels / classification for the DLP "label enforcement" rules

Description: The **sensitivity labels** (or other classification — sensitive info types, trainable classifiers) that the adaptive DLP rules will key on, published and in use on the in-scope workloads, so protection on **labeled** content can scale with the handler's risk level. **Why:** "Label enforcement" here is a **DLP rule combining the risk-level condition with a sensitivity-label condition** — the rule needs published labels applied to content to act on. **Verify:** Purview → **Information Protection** → **Labels / Label policies** shows the labels published; content in scope carries them (Activity explorer / Content explorer where available). **Implement if missing:** Publish and adopt the needed sensitivity labels first (this can be a separate labeling project). If you have no labels yet, the adaptive DLP policy can still key on **sensitive info**

types; add label conditions once labels are in use.

R6. DLP coverage on the in-scope workloads

Description: DLP enabled and healthy on the **workloads** the adaptive policy will cover (Exchange, SharePoint, OneDrive, Teams, and — for endpoint actions like USB/print/upload — **onboarded devices** for **Endpoint DLP**). **Why:** The adaptive DLP rule can only act where DLP itself operates; endpoint actions require device onboarding exactly as Endpoint DLP does. **Verify:** Purview → **Data Loss Prevention** → **Policies** shows healthy policies; **Settings** → **Device onboarding** shows onboarded devices (for endpoint rules). `PURVAP-Test-Readiness.ps1` reports DLP policy presence and whether the adaptive policy is in simulation/on. **Implement if missing:** Enable DLP on the needed workloads and onboard devices for any endpoint enforcement before relying on those actions.

R7. Conditional Access readiness (for the Elevated-risk access control)

Description: Entra **Conditional Access** available (Entra ID P2), a break-glass/emergency-access account **excluded** from any blocking policy, and agreement on the control for Elevated-risk users (block, require MFA / password change, or a limited/monitored session). **Why:** The CA integration lets access controls respond to insider risk; a blocking CA policy without a break-glass exclusion can lock out administrators. **Verify:** Entra → **Protection** → **Conditional Access**; confirm the **Insider risk** condition is selectable and a break-glass account is excluded. `PURVAP-Discovery.ps1` (Graph) reports CA policy presence where readable. **Implement if missing:** Ensure Entra ID P2, define/confirm a break-glass account and its exclusion, and agree the Elevated-risk control **before** authoring the CA policy. Deploy CA in **report-only** first.

R8. HR, legal, privacy (and works-council) engagement and lawful basis

Description: Named, engaged stakeholders from **HR, legal, privacy**, and — where applicable — **works councils / employee representatives**, plus a documented **lawful basis / notice / consultation** for the underlying insider-risk monitoring that drives Adaptive Protection. **Why:** Adaptive Protection acts on **people-derived risk**. In many regions the underlying monitoring **requires** notice, consultation, or a specific lawful basis before it runs; the **applicability is a legal determination**, and any judgement about a user's conduct remains **HR/legal's**, not the administrator's. **Verify:** Confirm the named stakeholders, the recorded lawful basis / notice, and the agreed IRM anonymization rules **in writing** before you enable enforcement. **Implement if missing: Stop** and obtain them. This is a hard gate — do not enable enforcing DLP or CA controls without it. (See `global-requirements-purview.md` §5.)

R9. Pilot scope and change control (simulation / test / report-only)

Description: A **named pilot scope** (a limited user group, `SG-AP-Pilot`) and agreement to run the DLP policy in **simulation/test** and the CA policy in **report-only** first, under a **change-control** process, before any enforcing, tenant-wide control. **Why:** DLP block actions and CA grant controls are high-impact; simulation/report-only prove the risk levels are assigned and the rules *would* act **without** disrupting legitimate work, and let you tune before enforcing. **Verify:** Confirm the pilot group exists, that DLP **simulation mode** and CA **report-only** are used, and a change window/approval path. `PURVAP-Set-Scope.ps1` (`-WhatIf`) previews pilot-group scoping. **Implement if missing:** Define the pilot group, deploy in simulation/report-only, and agree change control before turning on enforcement.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

Implementation — Adaptive Protection in Microsoft Purview

This is the ordered, do-this-then-that guide. It follows the standard model (**Assess** → **Design** → **Configure** → **Pilot (simulation/test / report-only)** → **Validate** → **Expand**) and — because Adaptive Protection is driven by people-monitoring signals — it confirms the **IRM source signal and its privacy guardrails FIRST**, then builds enforcement in **simulation/report-only** before anything blocks. Every object is named verbatim so the scripts, testing, and troubleshooting line up. Replace the `contoso.com` / sample group names with your own.

> ***Portal note.*** *Adaptive Protection **setup** (Quick/Custom, the risk-level mapping) is done in the **Microsoft Purview portal** (`purview.microsoft.com` → **Insider Risk Management** → **Adaptive Protection**). The **DLP policy** is authored in **Purview** → **Data Loss Prevention**; the **CA policy** in **Entra** → **Conditional Access**. PowerShell (S&C PowerShell / Graph) is used here for **readiness, DLP scaffolding, validation, and reporting** — not to invent a setup path a surface does not expose. Where a portal path or capability may differ by tenant/licence, **verify against your licensing/tenant.***
>
> ***Hard gate before you enforce.*** *Do **not** move DLP from simulation to enforce, or turn the CA policy on, until Requirement **R8** (HR/legal/privacy engagement + lawful basis for the underlying monitoring) is satisfied **in writing**. Adaptive Protection acts on people-derived risk; the applicability is a legal determination, not a technical one.*

Phase 0 — Assess (confirm you can build safely)

1. **Confirm licensing (R1).** Verify E5 / E5 Compliance (IRM + DLP) on in-scope users and **Entra ID P2 **for the CA integration. In Purview,** Insider Risk Management → Adaptive Protection** is present.

1. **Confirm the IRM source signal + privacy (R3).** Run `PURVAP-Discovery.ps1` (read-only). Confirm an insider-risk policy exists and is scoring, that IRM **anonymization** is on, and that IRM role separation is intact.

• **Gate 0a:** an IRM scoring source exists and privacy posture is on → continue. Otherwise stand up / fix the IRM policy first (see the IRM solution).

1. **Confirm roles across all three surfaces (R2).** IRM Admin, DLP (Compliance Administrator), and Conditional Access Administrator mapped to named people; break-glass account identified for CA (R7).

1. **Confirm the toolchain** (`global-requirements-purview.md` §3): `Connect-IPPSSession`, `Connect-ExchangeOnline`, and `Connect-MgGraph` all succeed with an MFA-capable admin.

Phase 1 — Design (agree it with HR/legal, then name everything)

Decide and **record with HR/legal/privacy**:

• **Setup mode (R4): Quick setup** (recommended default) to start, or **Custom setup** with an explicit mapping, e.g.:

• **Elevated** = a **high-severity** insider-risk alert (or the Custom threshold you agree).

• **Moderate** = a **medium-severity** alert.

• **Minor** = a **low-severity** alert.

• **Pilot scope:** a named group, `SG-AP-Pilot`, holding a small set of sanctioned pilot users.

• **The DLP policy** and its verbatim rule names (Phase 3):

• Policy: `DLP-Adaptive-Protection` (scoped to `SG-AP-Pilot`, **simulation/test** first).

• Rule `AP-Elevated-Block` — risk level **Elevated** → **block** (with policy tip).

• Rule `AP-Moderate-WarnOverride` — risk level **Moderate** → **block with override / warn** (user can justify and proceed).

• Rule `AP-Minor-Audit` — risk level **Minor** → **audit only** (allow, notify/record).

• **The label/classification condition (R5):** the sensitivity label(s) — e.g. **Confidential** / **Highly Confidential** — (or sensitive info types) each rule additionally requires, so protection keys on **labeled sensitive content**.

• **The Conditional Access policy:** `CA-InsiderRisk-Elevated` — Insider risk = **Elevated** → the agreed control (block, or require MFA / password change / limited session), **report-only** first, with the **break-glass account excluded**.

Phase 2 — Configure Adaptive Protection (the risk-level engine)

In **Purview** → **Insider Risk Management** → **Adaptive Protection**:

1. **Choose the setup path.** Select **Quick setup** (uses Microsoft's recommended default insider-risk policy and thresholds) or **Custom setup** (map **Elevated / Moderate / Minor** to your chosen insider-risk policies and thresholds from Phase 1).

1. **Turn Adaptive Protection on.** Confirm it reports as **active** and that in-scope users will begin receiving a **dynamic risk level** as their insider-risk scoring warrants.

1. **Confirm the risk level is available as a condition.** Begin authoring a DLP rule (Phase 3) and confirm the condition *"the user's risk level for adaptive protection is …"* is selectable. If it is not yet visible, allow propagation time and **verify availability in your tenant.**

• **Pass/fail:** Adaptive Protection shows active with the three levels defined; the DLP condition is selectable. **Rollback:** turning Adaptive Protection off stops new level assignment (existing DLP/CA rules simply stop matching the condition).

Phase 3 — Build the DLP enforcement in SIMULATION/TEST first

In **Purview** → **Data Loss Prevention** → **Policies** → **Create policy** (custom), create `DLP-Adaptive-Protection`, scoped to `SG-AP-Pilot`, on the in-scope workloads, and set the policy **mode to simulation / test** (e.g. *Test it out first* — run in test **without** showing policy tips initially). Then add three rules, each combining the **risk-level** condition with the **sensitivity-label** condition from Phase 1:

1. `AP-Elevated-Block`

• Conditions: risk level = **Elevated AND** content has the sensitivity label(s) (or SIT).

• Action: **Block** (restrict access / block the action), with a **policy tip**.

1. `AP-Moderate-WarnOverride`

• Conditions: risk level = **Moderate AND** the same label/classification condition.

• Action: **Block with override** / **warn** — the user is warned and may proceed with a business justification (recorded).

1. `AP-Minor-Audit`

• Conditions: risk level = **Minor AND** the same label/classification condition.

• Action: **Audit only** — allow, but generate an audit/alert record.

• **Pilot rule:** keep the policy in **simulation/test** and scoped to `SG-AP-Pilot`. Simulation shows what the rules **would** do (matches per level) **without blocking anyone**.

• **Pass/fail:** the policy shows **On (test/simulation)** and **healthy** (no configuration warning); simulation begins reporting matches once pilot users have risk levels. `PURVAP-Set-DlpPolicy.ps1 -WhatIf` validates prerequisites and prints the intended policy/rule plan before you build (its `-Commit` path can scaffold the policy shell in simulation mode; the **risk-level condition itself is added in the portal** where PowerShell does not expose it — **verify in your tenant**).

• **Rollback:** set the policy **mode = Disable** (or delete the rule); simulation changes nothing for users, so rollback in the pilot is trivial.

Phase 4 — Build the Conditional Access control in REPORT-ONLY first

In **Entra** → **Protection** → **Conditional Access** → **New policy**, create `CA-InsiderRisk-Elevated`:

1. **Users:** the pilot scope (`SG-AP-Pilot`), **excluding** the **break-glass** account (R7).

2. **Conditions** → **Insider risk:** set to **Elevated** (verify the condition is available with Entra ID P2).

1. **Grant / Session:** the agreed control — **block**, or **require MFA / password change**, or a **limited session** — per Phase 1.

1. **Enable policy: Report-only.** This evaluates the policy and logs what **would** happen **without** enforcing it.

• **Pass/fail:** the policy shows **Report-only**; sign-in logs show it evaluating for Elevated-risk

pilot users. **Rollback:** set the policy **Off**; report-only never blocks.

Phase 5 — Pilot and validate (run the gates)

Work the gates in `05-testing.md`. In summary, with a **sanctioned pilot test account**:

- Confirm Adaptive Protection assigns the account a **risk level** after sanctioned risky activity

(e.g. the insider-risk scoring the account triggers).

- In **DLP simulation**, confirm the matching rule (**Elevated/Moderate/Minor**) reports it **would**

take the mapped action on labeled content.

- In **CA report-only**, confirm the sign-in log shows `CA-InsiderRisk-Elevated` would apply when the

account is Elevated.

- Confirm reporting (`PURVAP-Report.ps1`) reconciles with **Activity explorer / DLP alerts** and the

CA report-only insights.

- **Do not enforce** until every gate passes **and** HR/legal confirm the approach (R8).

Phase 6 — Expand (enforce, then widen — only after the gate passes)

1. **Enforce DLP.** Change `DLP-Adaptive-Protection` **mode from simulation/test to enforce** (turn on

policy tips / actions). Watch the first cohort closely.

1. **Turn on Conditional Access.** Change `CA-InsiderRisk-Elevated` from **report-only to On**, with the

break-glass exclusion verified.

1. **Widen scope deliberately** — group-by-group, not tenant-wide in one move — using

`PURVAP-Set-Scope.ps1` (`-WhatIf` first) to stage `SG-AP-Pilot` → broader groups. **Re-run the gates** after each expansion. Keep the IRM privacy posture and role separation intact as you scale.

Rollback summary

Change	Rollback
Adaptive Protection mis-mapped	Adjust the level→threshold mapping (Custom setup), or revert to Quick setup; turn Adaptive Protection off to stop new level assignment.
DLP rule too aggressive	Set `DLP-Adaptive-Protection` **mode = simulation** (or Disable) — actions stop immediately; tune conditions and re-pilot.
DLP scoped too far	Remove the added members from `SG-AP-Pilot` (`PURVAP-Set-Scope.ps1`); the policy follows the group.

Change	Rollback
CA policy blocking legitimate work	Set `CA-InsiderRisk-Elevated` to **report-only** or **Off**; confirm the break-glass exclusion.
Risk levels too sensitive	Retune the IRM source policy / Custom thresholds so fewer users reach Elevated/Moderate.

> ***Never*** *treat a user's risk level as a finding of misconduct or a disciplinary trigger — it tightens* ***controls****, not judgement. Whether risky activity warrants a consequence is an* ***HR/legal determination*** *(see IRM); this solution automates protection, not decisions.*

Testing & Validation — Adaptive Protection in Microsoft Purview

Run these gates in order. Each has an explicit **pass/fail** signal. **Do not enforce** (Phase 6 — DLP to enforce, CA to on) until every gate passes **and** HR/legal have confirmed the approach is acceptable. Where a test involves a real user's activity, use a **sanctioned test account/action** with HR/legal awareness — do not covertly test on a real employee, because the underlying signal is insider-risk monitoring.

Use the scripts where noted; they are read-only or `-WhatIf`/simulation and change nothing you don't approve.

Gate 1 — Licensing and roles are in place

Why: Adaptive Protection spans three surfaces, each plan- and role-gated. **How:** Confirm E5 / E5 Compliance (IRM + DLP) and **Entra ID P2** (CA); confirm IRM/DLP/CA roles are assigned to named people. Run `PURVAP-Discovery.ps1`. **Pass:** Licensing present; **Insider Risk Management** → **Adaptive Protection** is available; the DLP **risk-level condition** is selectable; the CA **Insider risk** condition is available; roles assigned. **Fail:** Any surface missing its licence/role → acquire/assign before proceeding.

Gate 2 — The IRM source signal is scoring (and privacy is on)

Why: No IRM scoring source means no risk levels and no adaptive behavior. **How:** Purview → **Insider Risk Management** → **Policies** (a policy is **On** and scoring); **Settings** → **Privacy** (anonymization on). `PURVAP-Discovery.ps1` reports the policy signal and prompts to confirm privacy in-portal. **Pass:** An insider-risk policy is active and scoring; IRM anonymization is on and role separation intact. **Fail:** No scoring source, or privacy posture off without written exception → fix in IRM first.

Gate 3 — Adaptive Protection is active with the three levels defined

Why: The risk-level engine must be on before DLP/CA can read a level. **How:** Purview → **Insider Risk Management** → **Adaptive Protection** — confirm Quick or Custom setup and the **Elevated / Moderate / Minor** definitions. **Pass:** Adaptive Protection shows **active**; the three levels are defined per the agreed mapping; in-scope users are eligible for a dynamic level. **Fail:** Adaptive Protection inactive or

misconfigured, or levels undefined → complete Phase 2.

Gate 4 — The DLP policy is healthy, in SIMULATION, scoped to the pilot

Why: A mis-scoped or prematurely-enforcing DLP policy blocks legitimate work. **How:** Purview → **Data Loss Prevention** → **Policies**; `PURVAP-Set-DlpPolicy.ps1 -WhatIf` to re-validate the plan; `PURVAP-Test-Readiness.ps1` to confirm mode/scope. **Pass:** `DLP-Adaptive-Protection` is **On in simulation/test**, **healthy** (no configuration warning), scoped to `SG-AP-Pilot` only, with the three rules (`AP-Elevated-Block`, `AP-Moderate-WarnOverride`, `AP-Minor-Audit`) each combining the **risk-level** and **label/classification** conditions. **Fail:** Policy enforcing prematurely, over-scoped, unhealthy, or missing a rule/condition → correct before testing detections.

Gate 5 — The Conditional Access policy is in REPORT-ONLY with break-glass excluded

Why: A blocking CA policy without a break-glass exclusion can lock out administrators. **How:** Entra → **Conditional Access** — inspect `CA-InsiderRisk-Elevated`. **Pass:** The policy is **Report-only**, scoped to `SG-AP-Pilot`, uses the **Insider risk = Elevated** condition, applies the agreed grant/session control, and **excludes the break-glass account**. **Fail:** Policy already **On**, no break-glass exclusion, or wrong condition → set report-only and fix before enforcing.

Gate 6 — A sanctioned test account receives a risk level

Why: Proves the source→level path (IRM scoring → Adaptive Protection level) works. **How:** With a **pilot test account** in `SG-AP-Pilot`, perform **benign, sanctioned** activity that its insider-risk policy scores (per the IRM policy driving Adaptive Protection), then check the account is assigned a **risk level**. **Pass:** The account is assigned an **Elevated / Moderate / Minor** level consistent with the mapping, within the expected window. **Fail:** No level assigned → confirm the IRM policy is scoring the account (Gate 2), Adaptive Protection is active (Gate 3), and enough time has passed for propagation.

Gate 7 — DLP simulation shows the correct per-level action WOULD apply

Why: Proves the level→DLP-action path adapts by level, before anything blocks. **How:** With the Gate-6 account at a known level, perform a **sanctioned** action on **labeled** test content (e.g. attempt to share/copy a labeled test file). Review **Activity explorer / DLP simulation** results. **Pass:** Simulation shows the matching rule would act as mapped — **audit** at Minor, **warn/override** at Moderate, **block** at Elevated — on the labeled content, and **not** on unlabeled/out-of-condition content. **Fail:** No match, or the wrong rule matched → check the risk-level condition, the label condition, the workload coverage (and device onboarding for endpoint actions).

Gate 8 — CA report-only shows the Elevated control WOULD apply

Why: Proves the level→access-control path before enforcing access. **How:** With the test account at **Elevated**, have it sign in to an in-scope app; review the Entra **sign-in logs** → **report-only** results for `CA-InsiderRisk-Elevated`. **Pass:** The sign-in log shows the policy **would** apply the agreed control for the Elevated-risk account, and **would not** for a Minor/Moderate/normal account. **Fail:** Policy not evaluating, or applying to the wrong users → check the Insider risk condition, scope, and Entra ID P2.

Gate 9 — Reporting reconciles with the portal

Why: Leadership needs a defensible, privacy-respecting summary of adaptive enforcement. **How:** Run `PURVAP-Report.ps1` (read-only) and compare to **Activity explorer / DLP alerts** and the CA report-only insights. **Pass:** The rollup (matches/actions by risk level and workload over the window) reconciles with the portal, with no identity exposure beyond what the report is authorized to show. **Fail:** Rollup diverges materially from the portal → the portal is authoritative; reconcile before reporting.

Gate 10 — HR/legal confirm before enforcement

Why: The underlying monitoring's applicability, and any judgement about a user, are HR/legal's. **How:** Walk the adaptive behavior with HR/legal: how levels are assigned, what each level does to DLP/CA, and that a level is **not** a misconduct finding. **Pass:** HR/legal confirm the mapping, the controls, and that **determinations sit with them**; the lawful basis (R8) is recorded in writing. **Fail:** Ambiguity about applicability or ownership of outcomes → resolve **before** enforcing.

Exit criteria (all must be true before Expand/enforce)

- Licensing + roles across IRM/DLP/CA (Gate 1)
- IRM source signal scoring; privacy on (Gate 2)
- Adaptive Protection active; three levels defined (Gate 3)
- DLP policy healthy, simulation, pilot-scoped (Gate 4)
- CA policy report-only, break-glass excluded (Gate 5)
- Test account receives a risk level (Gate 6)
- DLP simulation: correct per-level action would apply (Gate 7)
- CA report-only: Elevated control would apply (Gate 8)
- Reporting reconciles with portal (Gate 9)
- HR/legal confirmed; lawful basis recorded (Gate 10)

Troubleshooting — Adaptive Protection in Microsoft Purview

Adaptive Protection spans three surfaces — **Insider Risk Management** (the signal), **DLP** and **Conditional Access** (the controls) — so most problems are really a break in the chain **activity** → **IRM score** → **risk level** → **DLP/CA action**. Work the chain in that order; the scripts (`PURVAP-Discovery.ps1`, `PURVAP-Test-Readiness.ps1`) tell you which link is broken. Where a symptom is licensing- or preview-related, **verify against your licensing/tenant** rather than assuming a bug.

No users are ever assigned a risk level

- **No IRM scoring source.** Adaptive Protection maps **IRM scoring** onto levels — if no insider-risk

policy is scoring the user, there is no level. Confirm an active IRM policy (`PURVAP-Discovery.ps1`; Purview → Insider Risk Management → Policies).

• **Adaptive Protection not active / not set up.** Confirm **Insider Risk Management → Adaptive Protection **shows active with** Elevated/Moderate/Minor** defined (Quick or Custom setup).

• **Thresholds too high (Custom setup).** If your Custom mapping requires high-severity alerts, few or no users will reach a level. Retune the mapping, or start with **Quick setup**.

• **Propagation delay.** Level assignment follows insider-risk scoring, which is not instantaneous. Allow time after the sanctioned test activity before concluding it failed.

The adaptive-protection risk-level condition is not visible when authoring a DLP rule

• **Licensing.** The condition requires the right licence (E5 / E5 Compliance) and **Adaptive Protection enabled**. Confirm in Billing and in the Adaptive Protection setup —** verify in your tenant**.

• **Adaptive Protection not yet on.** The condition only appears **after** Adaptive Protection is active. Complete Phase 2 first, then allow propagation time.

• **Portal-only surface.** The condition is added in the **portal**; do not expect to set it via PowerShell. `PURVAP-Set-DlpPolicy.ps1` scaffolds only the simulation-mode shell and hands the condition to the portal by design.

The wrong DLP action fires for a user's level (e.g. block at Minor)

• **Overlapping rules / precedence.** Ensure each rule keys on **one** level and the three levels are mutually exclusive; check DLP rule **priority** so a broad rule isn't shadowing a per-level one.

• **Missing label/classification condition.** If a rule omits the sensitivity-label/SIT condition it can match content it shouldn't. Confirm each rule combines **risk level AND label/SIT** (Phase 3).

• **Stale level.** Risk levels are **time-bound** and decay; a user you *expect* to be Elevated may have dropped to Moderate/Minor. Confirm the **current** level, not a past one.

DLP simulation shows no matches

• **Still no risk level (see above).** No level → the risk-level condition never matches.

• **No labeled content in scope.** The rules key on labeled/SIT content; if the test file has no label (or the label isn't published/applied), nothing matches. Confirm labels (R5).

• **Workload/device not covered.** Endpoint actions (USB/print/upload) require **device onboarding**; Exchange/SharePoint/OneDrive/Teams must be in the policy's locations (R6).

• **Simulation is working as intended.** Simulation reports what **would** happen — it does **not** block. Empty results with no risky test activity are expected, not a failure.

Conditional Access policy is not evaluating (report-only shows nothing)

- **Entra ID P2 / Insider risk condition.** The CA **Insider risk** condition needs **Entra ID P2**.

Confirm licensing and that the condition is selectable.

- **Scope/user mismatch.** Confirm the test account is in `SG-AP-Pilot` (the policy's scope) and is

not in an exclusion (e.g. the break-glass group).

- **User not Elevated.** `CA-InsiderRisk-Elevated` targets **Elevated**; a Moderate/Minor/normal user

won't trigger it. Confirm the account's current level.

- **Report-only insights lag.** Report-only results appear in **sign-in logs**; allow time and filter

by the policy name.

Risk of locking out administrators (Conditional Access)

- **Break-glass not excluded. Always** exclude the break-glass/emergency-access account from any

blocking CA policy, and verify the exclusion **before** turning the policy from report-only to on (R7). If lockout is occurring, set the policy to **report-only/Off** immediately and fix the exclusion.

"It blocked legitimate work after we enforced"

- **Enforced too early / too broadly.** Return the DLP policy to **simulation** (or the CA policy to

report-only) — this stops the impact immediately — then tune conditions and re-pilot on `SG-AP-Pilot` before re-enforcing.

- **Action too hard for the level.** Prefer **warn/override** at Moderate so legitimate work has a

justification path; reserve hard **block** for Elevated. Fix the **response**, or retune the **signal** so fewer users reach the hard-block level.

Permission / role errors running the scripts or authoring

- **IRM/DLP read access.** `PURVAP-Discovery.ps1` / `PURVAP-Test-Readiness.ps1` need read access to

compliance policies (Connect-IPPSSession). `Get-InsiderRiskPolicy` may be unavailable in some tenants/sessions — the scripts fall back to "confirm in portal."

- **Graph scopes.** `PURVAP-Set-Scope.ps1` needs `Group.ReadWrite.All` (and `User.Read.All`,

`Directory.Read.All`); `PURVAP-Discovery.ps1 -IncludeConditionalAccess` needs `Policy.Read.All`. Consent the delegated scopes with an admin.

- **Cross-surface roles.** Authoring spans IRM, DLP (Compliance Administrator), and CA (Conditional

Access Administrator). A "can't see/author" symptom is usually a **missing role on that specific surface** (R2) — not a product fault.

Reporting rollup doesn't match the portal

• **Portal is authoritative.** `PURVAP-Report.ps1` summarizes the **unified audit log**, which lags and may not expose per-risk-level detail. Reconcile against **Activity explorer / DLP alerts** and CA **report-only** insights — those are the source of truth.

• **Window/latency.** Widen `-Days`, and allow for audit ingestion latency before concluding records are missing.

> ***When in doubt, walk the chain:*** *is an IRM policy **scoring** the user? Is Adaptive Protection **active** with levels defined? Does the user have a **current** level? Do the DLP rules combine **risk level AND label**, and is the policy in the mode you expect? Is CA **Entra ID P2**, scoped, and the user **Elevated**? Each script maps to a link in that chain. And remember: a risk level tightens **controls**, not judgement — determinations remain with **HR/legal** (see IRM).*

Best Practices — Adaptive Protection in Microsoft Purview

Field-tested guidance for running Adaptive Protection well. It follows the same order the solution is built: get the **signal and its guardrails** right, then let the **risk level** drive protection — piloted, proportionate, and defensible.

1. Treat the risk level as an automation input, not a verdict

• A user reaching **Elevated** means their **controls tighten** — it is **not** a finding of wrongdoing. Communicate this internally so a risk level is never read as an accusation.

• Judgement about whether risky activity warrants a consequence is an **HR/legal determination** (via Insider Risk Management), not a technical default and not the administrator's call. Adaptive Protection automates **protection**, not decisions.

2. Protect the source signal's privacy

• Adaptive Protection is only as trustworthy as the **IRM policy** underneath it. Keep IRM **anonymization on** and **role separation** intact; scope the source policy to the **minimum** population.

• Deploy with **HR, legal, privacy** (and works-council where applicable) — the same stakeholders IRM requires. Record the **lawful basis** before enforcing; the applicability is a **legal determination** (`global-requirements-purview.md` §5).

3. Always pilot in simulation / report-only first

• **DLP** → **simulation/test** and **Conditional Access** → **report-only** are non-negotiable first states. They prove risk levels are assigned and the rules *would* act **without disrupting work**.

• Keep the pilot scoped to `SG-AP-Pilot` and expand **group-by-group** — never flip to enforce, tenant-wide, in one move. Re-run the gates after each expansion.

4. Make protection proportionate across the three levels

• Map actions so friction scales with risk: **Minor = audit**, **Moderate = warn/override**, **Elevated = block**. Blocking *everyone* defeats the point of Adaptive Protection; auditing *the risky* defeats it the other way.

• Reserve the hardest controls (DLP block, CA block/step-up) for **Elevated**, and prefer **override/justification** at Moderate so legitimate work has a path.

5. Key enforcement on classification, not just risk

• Combine the risk-level condition with a **sensitivity-label** (or SIT) condition so the strongest protection lands on your **most sensitive, labeled content** — not on everything a risky user touches. This is what makes "label enforcement" precise and defensible.

• If labels are still rolling out, start with sensitive info types and add label conditions as labeling matures (R5).

6. Tune the mapping deliberately (Custom setup)

• Start with **Quick setup** (recommended default) to get value fast; move to **Custom setup** only when you need explicit control over which insider-risk signals map to each level.

• If too many users reach Elevated/Moderate, **retune the source thresholds** (fewer/higher-severity triggers) rather than weakening the DLP/CA action — fix the **signal**, not the **response**.

7. Guard access continuity on the Conditional Access side

• Always **exclude a break-glass/emergency-access account** from any blocking CA policy, and test that exclusion before turning the policy on.

• Prefer a **graduated** access response (require MFA / password change / limited session) over a hard block where the business can tolerate it, reserving hard block for genuinely high-risk apps/data.

8. Let risk levels decay — don't hard-code them

• Risk levels are **dynamic and time-bound** by design; they **decrease automatically** as behavior normalizes. Do not build side-processes that pin a user at a level — that turns an adaptive control into a static punishment.

9. Report on adaptive behavior, not on people

• Report **counts by risk level, action, and workload** (`PURVAP-Report.ps1`) — the portal's **Activity explorer / DLP alerts** and **CA report-only insights** are authoritative.

• Keep leadership reporting **aggregate and privacy-respecting**; identity exposure follows IRM's role-gated, audited rules, not a reporting convenience.

10. Verify against your tenant — the surfaces evolve

• Adaptive Protection, the DLP risk-level condition, and the CA insider-risk condition are **licensing-dependent** and the portals **change**. Confirm capability availability and exact paths **against your licensing/tenant** rather than assuming; where a capability is in preview, treat it as such.

11. Keep the evidence trail intact

• Do **not** delete DLP alerts, IRM cases, or audit records to "clean up" — they are the defensible, HR/legal-facing evidence of how protection adapted. Retention/disposition of those records is a **records/legal determination**.

Deliverables Summary — Adaptive Protection in Microsoft Purview

Everything included in this solution, and what each piece is for.

Documentation

Document	Purpose
Solution Overview (`01-solution-overview.md`)	What Adaptive Protection delivers, the IRM-driven model (risk levels → DLP/CA controls), the privacy sensitivity, and the Assess→Design→Configure→Pilot→Validate→Expand model.
Requirements (`02-requirements.md`)	Adaptive-Protection-specific prerequisites — licensing across IRM/DLP/Entra ID P2, roles on all three surfaces, the IRM source signal, Quick vs Custom setup, sensitivity labels, DLP/endpoint coverage, Conditional Access readiness, HR/legal engagement + lawful basis, pilot/change control.
Implementation (`03-implementation.md`)	Ordered steps: confirm the IRM signal + privacy first, enable Adaptive Protection, build the DLP policy in **simulation** and the CA policy in **report-only**, validate, then enforce and expand — with pass/fail gates and rollback.
Testing & Validation (`05-testing.md`)	Ten pass/fail gates from licensing/roles and the IRM signal through DLP-simulation and CA-report-only proof of per-level behavior to the HR/legal confirmation before enforcement.

Document	Purpose
Troubleshooting (`06-troubleshooting.md`)	The common Adaptive Protection failure modes (no risk levels assigned, DLP condition not visible, wrong per-level action, CA not evaluating, propagation delays, role/permission issues) and how to resolve them.
Best Practices (`07-best-practices.md`)	Risk-level-as-automation-not-verdict, protect the source signal's privacy, pilot-first, proportionate per-level actions, classification-keyed enforcement, deliberate tuning, access continuity, and evidence integrity.
Executive Summary (`executive-summary.md`)	One-page business framing for decision-makers.

PowerShell tools (5)

All tools are **read-only or `-WhatIf`/simulation by default**, authenticate **interactively** (no credentials in code), and use **Security & Compliance PowerShell** (`Connect-IPPSSession`), **Exchange Online** (`Connect-ExchangeOnline`), and/or **Microsoft Graph** (`Connect-MgGraph`). Adaptive Protection **setup** and the DLP **risk-level condition** are portal actions; these tools handle readiness, DLP scaffolding, validation, reporting, and scoping.

Script	Type	What it does
`PURVAP-Discovery.ps1`	Read-only	Adaptive Protection **readiness/discovery**: reports the IRM source-policy signal (present/scoring where readable), prompts to confirm the IRM privacy posture in-portal, inventories existing DLP policies and whether any rule already references the adaptive-protection risk-level condition, and (via Graph) reports Conditional Access policy presence. Changes nothing.

Script	Type	What it does
`PURVAP-Set-DlpPolicy.ps1`	`-WhatIf` default	**DLP-policy configuration helper**: validates prerequisites and prints the exact intended `DLP-Adaptive-Protection` policy/rule plan (three per-level rules, simulation-first, label-keyed); its `-Commit` path can scaffold the policy shell **in simulation mode** with documented conditions, and flags that the **risk-level condition is added in the portal** where PowerShell does not expose it — "verify availability in your tenant".
`PURVAP-Test-Readiness.ps1`	Read-only	**Validation checker**: reports whether Adaptive Protection prerequisites are met — DLP policy present and in **simulation/enforce**, its scope, workload/device signals, and licensing/integration hints — as pass/fail lines aligned to `05-testing.md`.
`PURVAP-Report.ps1`	Read-only	**Enforcement reporting rollup**: summarizes adaptive DLP activity readable from the unified audit log (by action/workload/time) to CSV for a leadership rollup; notes Activity explorer / DLP alerts and CA report-only insights as authoritative.
`PURVAP-Set-Scope.ps1`	`-WhatIf` default	**Scope helper**: previews and (with `-WhatIf:$false`) applies membership changes to the pilot/scope group (`SG-AP-Pilot`) so expansion stays deliberate and reversible; the DLP/CA policies follow the group.

Named objects (verbatim — used across docs, scripts, and tests)

- **Pilot scope group:** `SG-AP-Pilot`
- **Risk levels: Elevated**, **Moderate**, **Minor**
- **DLP policy:** `DLP-Adaptive-Protection` (simulation/test first), with rules:
- `AP-Elevated-Block` — risk level **Elevated** → block (policy tip)

• `AP-Moderate-WarnOverride` — risk level **Moderate** → block with override / warn

• `AP-Minor-Audit` — risk level **Minor** → audit only

• **Conditional Access policy:** `CA-InsiderRisk-Elevated` — Insider risk = **Elevated** → agreed control (block / step-up / limited session), report-only first, break-glass excluded

What this solution deliberately does NOT do

• It does **not** treat a risk level as a **finding of misconduct** or a disciplinary trigger — those determinations are HR/legal's.

• It does **not** enforce DLP/CA before piloting in **simulation/report-only** and passing the gates.

• It does **not** weaken the IRM privacy guardrails (anonymization, role separation) that produce the source signal.

• It does **not** invent portal paths or cmdlets — where Adaptive Protection setup or the risk-level condition is portal-only, the tools stop at readiness/validation/scaffolding and say so.

• It does **not** decide your **lawful basis** for the underlying monitoring — that is a legal determination for your jurisdiction(s).

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

PURVAP-Discovery.ps1

Purpose: Connects to Security & Compliance PowerShell (and, optionally, Microsoft Graph) to assess readiness for Microsoft Purview ADAPTIVE PROTECTION. It reports whether an Insider Risk Management source policy is present/scoring where readable (Adaptive Protection maps IRM scoring onto Elevated/Moderate/Minor risk levels), inventories existing DLP policies and whether any DLP rule already references the adaptive-protection risk-level condition, prompts you to confirm the IRM privacy (anonymization) posture in the portal, and — if Graph is available — reports Conditional Access policy presence. Read-only — it changes nothing. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVAP-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\PURVAP-Discovery.ps1 -IncludeConditionalAccess

How to run: powershell -ExecutionPolicy Bypass -File .\PURVAP-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\PURVAP-Discovery.ps1 -IncludeConditionalAccess

PURVAP-Report.ps1

Purpose: Queries the unified audit log for DLP enforcement activity over a window and produces a leadership rollup (by action/workload/time) to CSV — evidence of how protection adapted. It is READ-ONLY. The portal's Activity explorer / DLP alerts and the Conditional Access report-only insights are AUTHORITATIVE; this rollup is a convenience summary. Risk-level attribution is surfaced only where the audit records expose it — otherwise report by DLP action/workload and reconcile per-level detail in Activity explorer. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVAP-Report.ps1 powershell -ExecutionPolicy Bypass -File .\PURVAP-Report.ps1 -Days 14 -OutputCsv .\ap-rollup.csv

How to run: powershell -ExecutionPolicy Bypass -File .\PURVAP-Report.ps1 powershell -ExecutionPolicy Bypass -File .\PURVAP-Report.ps1 -Days 14 -OutputCsv .\ap-rollup.csv

PURVAP-Set-DlpPolicy.ps1

Purpose: Validates prerequisites and prints the exact intended plan for the DLP-Adaptive-Protection policy and its three risk-level rules (AP-Elevated-Block / AP-Moderate-WarnOverride / AP-Minor-Audit), then — only with -Commit — SCAFFOLDS the policy shell in SIMULATION mode (TestWithoutNotifications) using documented DLP cmdlets. It DEFAULTS TO -WhatIf (preview only) and creates nothing until you re-run with -Commit -WhatIf:$false. IMPORTANT: the adaptive-protection RISK-LEVEL CONDITION and pilot-group scoping are added in the PORTAL where PowerShell does not expose them — the scaffold creates a safe simulation-mode shell and tells you exactly what to finish in the portal. It never enforces and never blocks. HOW TO RUN Preview the plan (default, no changes): powershell -ExecutionPolicy Bypass -File .\PURVAP-Set-DlpPolicy.ps1 Scaffold the simulation-mode policy shell (still no enforcement): powershell -ExecutionPolicy Bypass -File .\PURVAP-Set-DlpPolicy.ps1 -Commit -WhatIf:$false

How to run: Preview the plan (default, no changes): powershell -ExecutionPolicy Bypass -File .\PURVAP-Set-DlpPolicy.ps1 Scaffold the simulation-mode policy shell (still no enforcement): powershell -ExecutionPolicy Bypass -File .\PURVAP-Set-DlpPolicy.ps1 -Commit -WhatIf:$false

PURVAP-Set-Scope.ps1

Purpose: Manages membership of the Adaptive Protection pilot/scope group (SG-AP-Pilot by default) so you can expand a rollout from pilot to production a batch at a time, and reversibly. Because the DLP-Adaptive-Protection policy (and the CA-InsiderRisk-Elevated policy) are scoped to this group, growing the group expands coverage without editing each policy. It DEFAULTS TO -WhatIf (preview only) and changes nothing until you re-run with -WhatIf:$false. It only ADDS the members you pass and never retargets policies directly, so expansion stays deliberate. Scoping people into adaptive protection is privacy-sensitive (the signal is insider risk) — do it only within the HR/legal-agreed scope. HOW TO RUN Preview (default): powershell -ExecutionPolicy Bypass -File .\PURVAP-Set-Scope.ps1 -AddMembers user1@contoso.com,user2@contoso.com Apply (after review + change approval + HR/legal-agreed scope): powershell -ExecutionPolicy Bypass -File .\PURVAP-Set-Scope.ps1 -AddMembers user1@contoso.com -WhatIf:$false

How to run: Preview (default): powershell -ExecutionPolicy Bypass -File .\PURVAP-Set-Scope.ps1 -AddMembers user1@contoso.com,user2@contoso.com Apply (after review + change approval + HR/legal-agreed scope): powershell -ExecutionPolicy Bypass -File .\PURVAP-Set-Scope.ps1 -AddMembers user1@contoso.com -WhatIf:$false

PURVAP-Test-Readiness.ps1

Purpose: Runs read-only checks aligned to 05-testing.md and reports each as PASS / FAIL / CONFIRM-IN-PORTAL: that an IRM scoring source is readable (Gate 2), that the DLP-Adaptive-Protection policy exists, its MODE (simulation vs enforce), and that its three risk-level rules are present (Gate 4). It does NOT change anything. Adaptive Protection SETUP and the CA policy are portal/Graph objects — the script points you to confirm those in-portal where it cannot read them. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVAP-Test-Readiness.ps1 powershell -ExecutionPolicy Bypass -File .\PURVAP-Test-Readiness.ps1 -PolicyName DLP-Adaptive-Protection

How to run: powershell -ExecutionPolicy Bypass -File .\PURVAP-Test-Readiness.ps1 powershell -ExecutionPolicy Bypass -File .\PURVAP-Test-Readiness.ps1 -PolicyName DLP-Adaptive-Protection